



Тестирование безопасности. Тестирование на проникновение

Студенты группы АС-63
Логинов Г.
Филипчук Д.
Кульбеда К.

Введение: Безопасность в цифровую эпоху

Средняя стоимость утечки данных в 2023 году:

\$4.45M

(Источник: IBM)

Тестирование безопасности — это переход от реактивной защиты к проактивному поиску уязвимостей до того, как их найдут злоумышленники.



Аудит безопасности

Проверка соответствия стандартам и политикам.



Оценка уязвимостей

Автоматизированный поиск известных слабых мест.



Тестирование на проникновение

Активная имитация реальной атаки для оценки реальной защищённости.

Что такое тестирование на проникновение (пентестинг)?



Авторизованная, симулированная атака на систему с целью оценки её безопасности.

Это не просто поиск уязвимостей, а их **реальная эксплуатация** в контролируемых условиях для демонстрации бизнес-рисков.



Проактивная защита:

Найти и устранить уязвимости до их эксплуатации злоумышленниками.



Соответствие стандартам:

Выполнение требований регуляторов (PCI DSS, GDPR).



Оценка ROI в безопасность:

Проверка реальной эффективности защитных мер.

Результат: детальный отчёт с практическими рекомендациями по усилению защиты.

Ключевая терминология: Глубина и подходы



Vulnerability Assessment

"Что у нас есть?"

Автоматическое сканирование на известные уязвимости. Широкий охват, малая глубина.



Penetration Testing

"Можно ли это взломать?"

Активная эксплуатация уязвимостей для демонстрации реального риска. Целенаправленная глубина.



Red Teaming

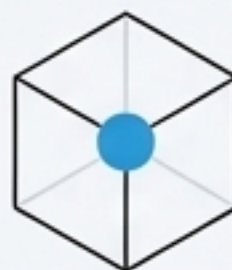
"Выдержит ли наша защита целенаправленную атаку?"

Полномасштабная симуляция, проверяющая людей, процессы и технологии.



Чёрный ящик (Black Box)

Нулевая информация. Имитация внешнего злоумышленника.



Белый ящик (White Box)

Полная информация (исходный код, архитектура). Максимальная глубина анализа.



Серый ящик (Grey Box)

Частичная информация (учётные данные). Имитация инсайдера.

Методологии: Систематический подход к взлому

Эффективный пентестинг опирается на стандартизированные фреймворки, обеспечивающие полноту и воспроизводимость.

OWASP Testing Guide



"Золотой стандарт" для веб-приложений и API.

PTES (Penetration Testing Execution Standard)



Универсальный стандарт для комплексного пентестинга (7 чётких фаз).

NIST SP 800-115



Формализованный подход для госсектора и регулируемых отраслей.

На практике часто используется гибридный подход, адаптированный под конкретную цель.

Этапы пентеста, Часть I: Подготовка и разведка

1



Разведка (Reconnaissance)

- **Цель:** Сбор максимального количества информации о цели.
- **Пассивная (OSINT):** Анализ открытых источников (Google Dorks, соцсети, DNS) без прямого контакта.
- **Активная:** Сканирование портов (Nmap) для поиска потенциальных точек входа.

2



Сканирование и перечисление (Scanning & Enumeration)

- **Цель:** Обнаружение известных уязвимостей и детальное изучение сервисов.
- **Инструменты:** Автоматизированные сканеры (Nessus, OpenVAS) и ручная верификация находок.

Этапы пентеста, Часть II: Эксплуатация и отчёт

3



Получение доступа (Gaining Access)

Цель: Эксплуатация уязвимостей (SQL-инъекции, XSS) для проникновения в систему.

Реальный случай: Уязвимость в Apache Struts привела к утечке данных 147 млн клиентов **Equifax**.

4



Закрепление в системе (Maintaining Access)

Цель: Имитация действий злоумышленника по сохранению доступа (бэкдоры, повышение привилегий).

Реальный случай: Атака на **Target** через подрядчика привела к компрометации 40 млн карт.

5



Заметание следов и отчётность (Covering Tracks & Reporting Tracks & Reporting)

Ключевой результат:
Детальный отчёт с описанием уязвимостей, оценкой рисков и **конкретными рекомендациями по их устранению**.

Арсенал пентестера: Цифровые инструменты



Kali Linux: Операционная система.

Стандарт индустрии, >600 инструментов.



Metasploit Framework: Фреймворк для эксплуатации.

Огромная база эксплойтов.



Burp Suite: Инструмент №1 для веб-пентеста.

Прокси для перехвата и анализа трафика.



Wireshark: Анализатор сети.

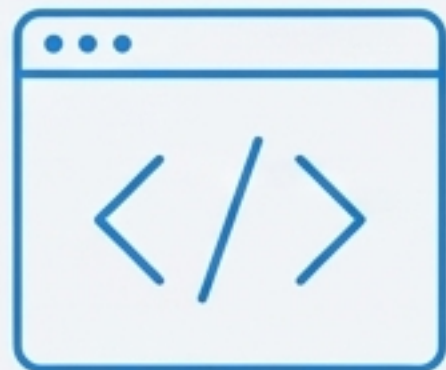
Глубокий анализ сетевых пакетов.



Social-Engineer Toolkit (SET): Инструмент для соц. инженерии.

Автоматизация фишинговых атак.

Типы пентестинга: Цифровые активы



1. Тестирование веб-приложений

Цель: Поиск уязвимостей OWASP Top 10 (SQL-инъекции, XSS).

Пример: Атака на **British Airways** (утечка 380,000 транзакций).



2. Тестирование сетевой инфраструктуры

Цель: Анализ фаерволов, VPN, Wi-Fi сетей.

Пример: Атака на **Colonial Pipeline** через скомпрометированный VPN-аккаунт.



3. Тестирование мобильных приложений

Цель: Анализ приложений на iOS/Android, хранение данных, API.

Пример: Уязвимости в приложениях для знакомств, позволявшие отслеживать местоположение.

Типы пентестинга: Человеческий фактор и физический мир

Зачастую самое слабое звено — не технология, а человек.



4. Социальная инженерия

- **Цель:** Оценка уязвимости персонала к манипуляциям.
- **Методы:** Фишинг, вишинг (звонки), создание ложных сценариев.
- **Пример:** Масштабный взлом **Twitter** в 2020 году через манипуляцию сотрудниками.



5. Физический пентест

Цель: Проверка физической безопасности офисов и серверных комнат.

Методы: Тейлгейтинг (проход за сотрудником), подделка пропусков, взлом замков.

Вывод: Цифровая защита бессмысленна без надёжной физической.

Правовые и этические аспекты: Правила игры

Деятельность на грани закона, требующая абсолютной ответственности.



Законность

- **Письменное разрешение — абсолютная необходимость.** Без него любая атака — уголовное преступление (УК РБ ст. 349-352, УК РФ ст. 272-274).
- Чёткое определение **Scope** (области тестирования) защищает и заказчика, и исполнителя.



Этика

- **Не навреди:** Минимизировать влияние на рабочие процессы.
- **Конфиденциальность:** Вся полученная информация строго конфиденциальна.
- **Ответственное раскрытие (Responsible Disclosure):** Сначала сообщить владельцу, дать время на исправление.

Карьера в пентестинге: Востребованная профессия

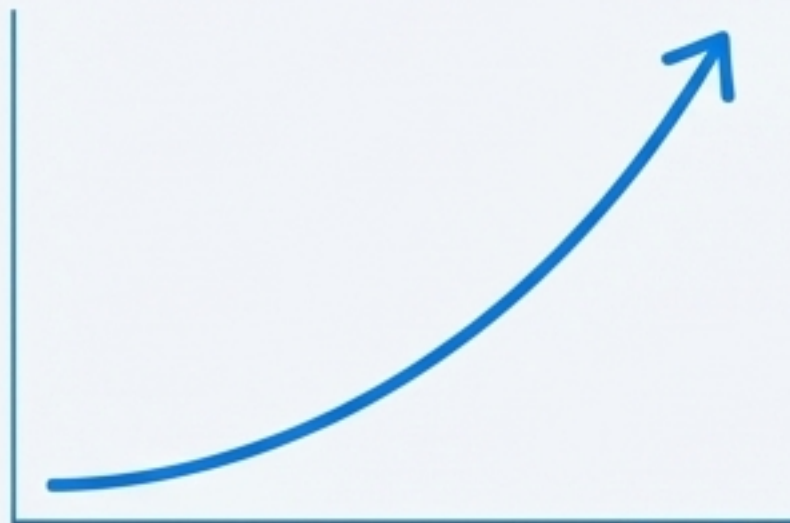
Спрос на квалифицированных специалистов стабильно превышает предложение.

1. Профессиональные сертификации



CEH (фундамент), OSCP ("золотой стандарт" практики).

2. Высокий потенциал дохода



Зарплаты значительно превышают средние по IT-отрасли.

3. Альтернативные пути (Bug Bounty)



Платформы HackerOne и Bugcrowd позволяют зарабатывать, находя уязвимости.

Вдохновляющий пример: Сантьяго Лопес (@santuber) стал первым исследователем, заработавшим более \$1,000,000 на Bug Bounty.

Заключение: Безопасность — это процесс, а не продукт



Проактивная защита — необходимость.

Регулярный пентестинг — это инвестиция, а не затрата.

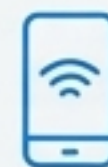


Пентестинг — это цикл.

Рекомендуется проводить тестирование ежегодно и после значительных изменений.



Будущее уже здесь. Новые вызовы: безопасность облачных сред, Интернета вещей (IoT) и систем Искусственного Интеллекта.



Инвестиции в пентестинг — это инвестиции в устойчивость и доверие в цифровом мире.

Благодарим за внимание!

Готовы ответить на ваши вопросы.